武汉大学 国家网络安全学院
SCHOOL OF CYBER SCIENCE AND ENGINEERING·WHU

信息系统安全

（Information System Security）

武汉大学
王鹃

jwang@whu.edu.cn

目录

- 信息系统安全概述
- 软件安全与恶意代码
- 渗透测试方法及工具
- 模糊测试与漏洞挖掘
- 用户身份认证机制
- 访问控制模型
- 操作系统基础安全机制
- 硬件安全与可信计算
- 系统风险评估方法与工具
- 信息系统安全研究新方向

第一章 信息系统安全概述

信息系统安全概述

1 安全威胁及实例

2 信息安全基本概念

3 安全模型

安全威胁及实例

超30省市曝安全管理漏洞，数千万社保用户敏感信息或遭泄露

2015年4月围绕社保系统、户籍查询系统、疾控中心、医院等大量曝出高危漏洞的省市已经超过30个，仅社保类信息安全漏洞统计就达到5279.4万条，涉及人员数量达数千万，其中包括个人身份证、社保参保信息、财务、薪酬、房屋等敏感信息。

安全威胁及实例

➢淘宝9900万账户信息遭窃

- 2016年2月1日，嘉兴平湖警方破获的一起网络黑产案件中，犯罪团伙利用互联网上非法流传的非淘宝用户账号和密码对淘宝账号进行“撞库”匹配，用于抢单等灰黑产行为等，涉案金额高达200余万元。该团伙通过租用阿里云服务器进行“撞库”。犯罪团伙利用手中已有的非淘宝账号对淘宝网进行了9900多万次比对，匹配后发现有2059万账户真实存在。

安全威胁及实例

➢电信诈骗导致高中生徐玉玉身亡

• 2016年高考，徐玉玉以568分的成绩被南京邮电大学录取。19日下午4点30分左右，她接到了一通陌生电话，对方声称有一笔2600元助学金要发放给她。在这通陌生电话之前，徐玉玉曾接到过教育部门发放助学金的通知。“18日，女儿接到了教育部门的电话，让她办理了助学金的相关手续，说钱过几天就能发下来。”徐玉玉的母亲李自云告诉记者，由于前一天接到的教育部门电话是真的，所以当时他们并没有怀疑这个电话的真伪。按照对方要求，徐玉玉将准备交学费的9900元打入了骗子提供的账号……发现被骗后，徐玉玉万分难过，当晚就和家人去派出所报了案。在回家的路上，徐玉玉突然晕厥，不省人事，虽经医院全力抢救，但仍没能挽回她18岁的生命。

安全威胁及实例

Hacking Team

2015年7月专门从事hacking活动的被黑，超过400G的数据泄露，其中不仅有Hacking Team雇员的邮件，还有远程控制系统的源代码，商业文档，以及更多重要的东西。

Hacking Team的远程控制软件，结合了UEFI（统一可扩展固件接口），能在主板BIOS中隐藏自身。

安全威胁及实例

XCodeGhost

2015年9月非官方发布的xcode安装包中，被别有用心的人植入了远程控制模块，通过修改xcode编译参数，将这个恶意模块自动的部署到任何通过xcode编译的苹果APP(iOS/Mac)中。

安全威胁及实例

- 危害
  - 在受感染的APP启动、后台、恢复、结束时上报信息至黑客控制的服务器。上报的信息包括：APP版本、APP名称、本地语言、iOS版本、设备类型、国家码等设备信息，能精准的区分每一台iOS设备。
  - 黑客可以下发伪协议命令在受感染的iPhone中执行
  - 黑客可以在受感染的iPhone中弹出内容由服务器控制的对话框窗口。

- 影响

AppStore下载量最高的5000个APP中有76款APP被XCodeGhost感染，高德地图、滴滴出行、微信iOS等也在感染之列，也有不少金融类应用，还有诸多民生类应用。根据保守估计，受这次事件影响的用户数超过一亿。

安全威胁及实例

毒液漏洞

2015年5月安全机构crowdstrike的报道，流行的大多数虚拟化平台存在VENOM（毒液）漏洞，该漏洞存在于虚拟主机中的模拟软驱中，使用该漏洞能让攻击者越过虚拟化技术的限制，访问并监视控制宿主机，并通过宿主机的权限来访问控制其他虚拟主机。

安全威胁及实例

- **危害**

漏洞可以越过虚拟化平台的限制，直接控制宿主机，危害比较严重。

一旦控制宿主机，利用宿主机强大的性能，可以进行比特币挖矿、密码暴力破解、或者获取宿主机所有的虚拟机上的RSA私匙、数据库等。

WannaCry

- **影响**

已知的XEN、KVM、QEMU受此漏洞的影响，影响全球数百万虚拟机安全

安全威胁及实例

海康威视监控设备存严重漏洞，部门设备被境外IP控制- 2015年2月

海康威视发表声明称，此事是因为部分在互联网上的海康威视设备采用了弱口令。

尽管公司进行了紧急停牌处理，但在对相关情况进行沟通说明后复牌时，海康威视股价还是遭遇了大跌，并一度跌停，单日市值蒸发90亿元。

安全威胁及实例

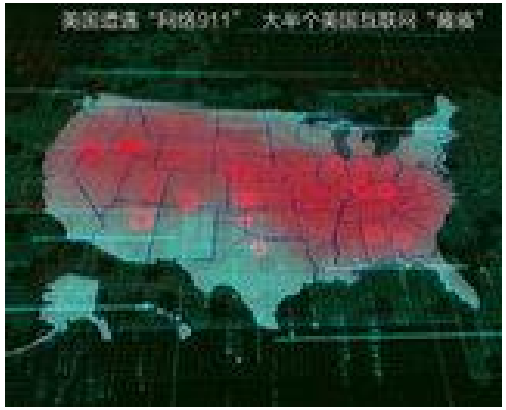
➢ Ramnit恶意代码

- 2016年4月，CNCERT监测发现，一个名为“Ramnit”的网页恶意代码被挂载在境内近600个党政机关、企事业单位网站上，一旦用户访问网站就有可能受到挂马攻击，对网站访问用户的PC主机构成安全威胁。Ramnit恶意代码是一个典型的VBScript蠕虫病毒，可通过网页挂马的方式进行传播，当用户浏览含有Ramnit恶意代码的HTML页面时，点击加载ActiveX控件，用户主机就很有可能受到恶意代码的感染。

安全威胁及实例

➢ Dyn事件

- 2016年10月21日，提供动态DNS服务的Dyn DNS遭到了大规模DDoS攻击，攻击主要影响其位于美国东区的服务。此次攻击导致许多使用DynDNS服务的网站遭遇访问问题，其中包括 GitHub、Twitter、Airbnb、Reddit、Freshbooks、Heroku、SoundCloud,、Spotify 和 Shopify。攻击导致这些网站一度瘫痪，Twitter甚至出现了近24小时0访问的局面。



安全威胁及实例

➢利用恶意软件Mirai发起DDoS攻击

Mirai主要是以网络摄像头、路由器、数码录像机等物联网（IoT）设备为跳台进行DDoS攻击。

安全威胁及实例

➢僵尸网络HNS感染逾2万物联网设备

- 2018年黑客使用定制的点对点通信来诱捕新的物联网设备并构建其基础设施（尤其是IP摄像机）。
- 影响范围：僵尸程序可以通过与Reaper相同的漏洞（CVE-2016-10401和其他针对网络设备的漏洞），对一系列设备进行Web开发，HNS还可以执行多个命令，包括数据泄露、代码执行和对设备操作的干扰。

安全威胁及实例

- 史上最大规模，勒索病毒WannaCry席卷全球

2017年5月29日，新型"蠕虫"式勒索病毒WannaCry爆发，席卷全球。目前已经有美、英中、俄、西、意等过百个国家和地区遭遇其攻击。两天时间，约2242.3万个IP地址遭受"永恒之蓝"漏洞攻击;据了解，电脑被这种勒索软件感染后，其中文件会被加密锁住。目前只有两种解决方案，第一种向黑客支付他们所要求的赎金5个比特币(价值为人们币5万多元)后才能解密恢复。第二种，如果不想支付赎金，则只能舍弃电脑中的文件。

安全威胁及实例

➢WPA2协议漏洞曝出协议层缺陷

在2017年10月，越来越普及的Wi-Fi，在标准协议上曝出了逻辑缺陷，导致几乎所有支持WPA/WPA2加密的无线设备都面临着入侵威胁。被发现的WPA2协议漏洞，主要针对Wi-Fi接入的客户端(如手机、平板、笔记本电脑等)设备，可通过密钥重装攻击(Key Reinstallation AttacK，KRACK)，诱发上述客户端进行密钥重装操作，以完成相互认证，进而实现WAP2加密网络的破解。

安全威胁及实例

- **CPU芯片漏洞-Meltdown”（熔断）和“Spectre”（幽灵）**

2018年黑客利用芯片指令设计时的乱序处理逻辑缺陷，对Intel的处理器，甚至是AMD、ARM造成重大威胁，使得应用程序可以拥有内核级别的高权限。

震网病毒

- 利郎布什尔核电站

2010年6月
被发现

- 它是第一个专门定向攻击真实世界中基础（能源）设施的“蠕虫”病毒，比如核电站，水坝，国家电网。
- 伊朗布什尔核电站受到严重攻击。
- 病毒可以修改用于生产浓缩铀的离心机的参数，使其倒转

震网病毒

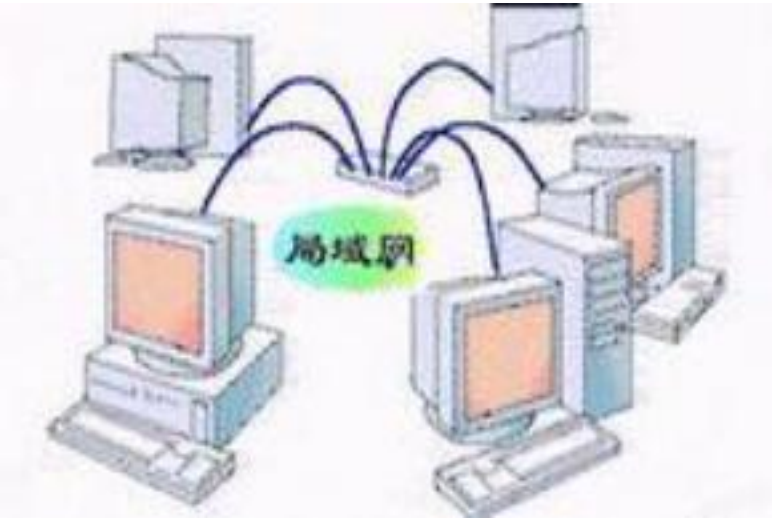
- Stuxnet到底是什么？
  - 蠕虫病毒
  - 利用微软至少四个漏洞
  - 伪造驱动程序的数字签名
  - 针对西门子公司的数据采集与监控系统SIMATIC WinCC进行攻击

震网病毒

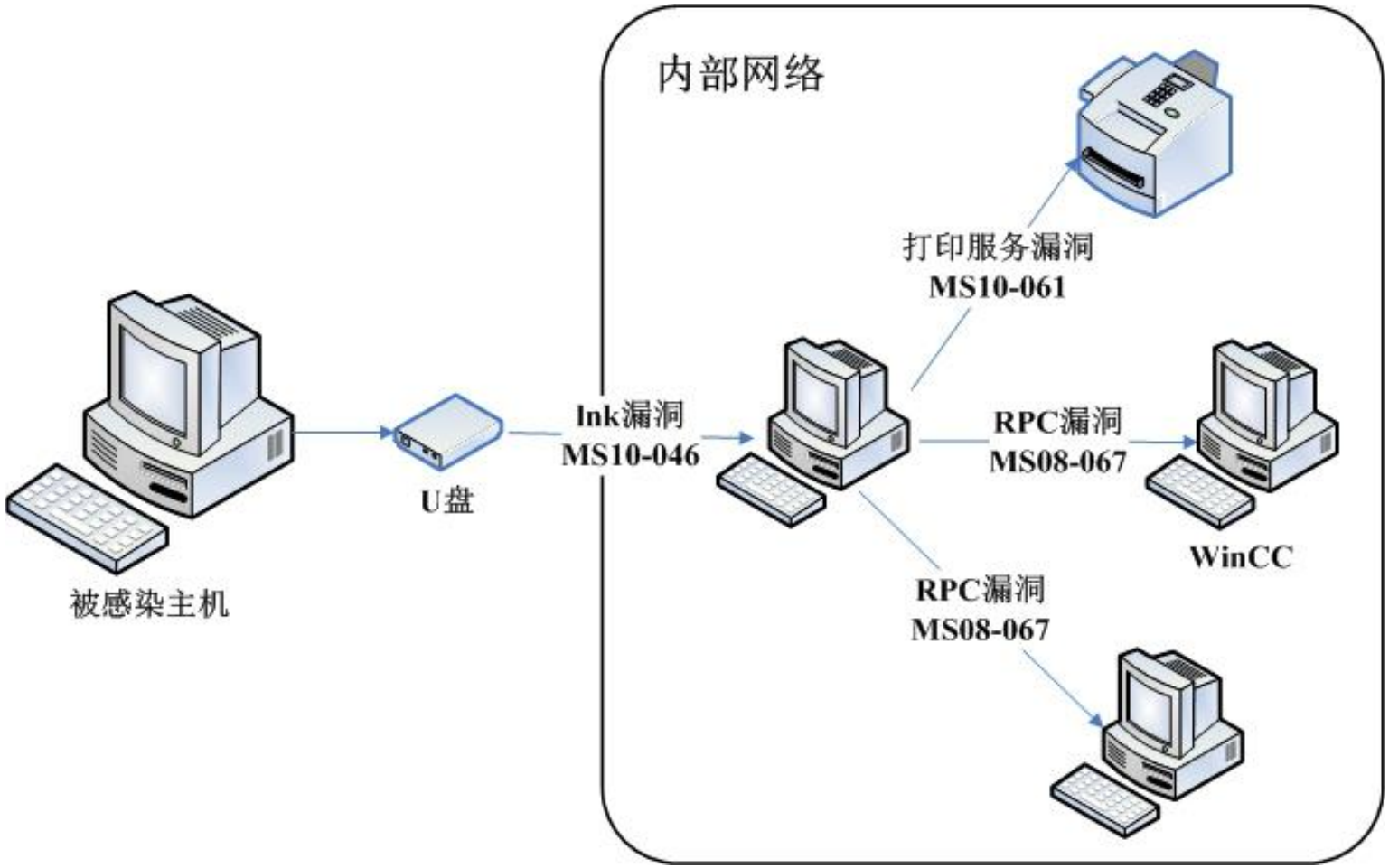
- Stuxnet的运行环境？
  - Windows 2000、Windows Server 2000
  - Windows XP、Windows Server 2003
  - Windows Vista
  - Windows 7、Windows Server 2008
  - 当它发现自己运行在非Windows NT系列操作系统中，即刻退出
  - 被攻击的软件系统包括：
  - SIMATIC WinCC 7.0
  - SIMATIC WinCC 6.2

传播工具

U盘



Stuxnet的多种传播方式



驱动程序隐藏某些link文件

```
loc_11703:
cmp     esi, 4
jle     short loc_1171D

push    4
lea     eax, [ebx+esi*2-8]
push    eax
mov     eax, offset a_lnk ; ".LNK"
call    sub_114DA
test    al, al
jnz     short loc_1172F

loc_1171D:
```

mrxnet.sys通过修改一些内核调用来隐藏被拷贝到U盘的lnk文件和DLL文件

RPC 远程执行漏洞与权限提升漏洞

特点：简单 、波及范围广、危害程度高

Stuxnet利用这一漏洞时，如果权限不够导致失败，还会使用一个尚未公开的漏洞来提升自身权限，然后再次尝试攻击。

地址	反汇编	文本字串
100188BC	PUSH Region00.10061C74	ncalrpc:[%s]
10018934	PUSH Region00.10061CE0	ncacn_ip_tcp:%s[%u]
10018955	PUSH Region00.10061C10	ntsvcs
10018977	MOV EBX,Region00.10061C00	browser
10018B13	PUSH Region00.10061D30	ncacn_ip_tcp
10018B56	PUSH Region00.10061D08	ncacn_ip_tcp:%s[%s]
10018E2F	PUSH Region00.1005C3FA	h
10018E51	PUSH Region00.1005C422	h
10018E73	PUSH Region00.1005C462	h
10018E95	PUSH Region00.1005C490	h
10018EB7	PUSH Region00.1005C4BE	h
10018ED8	PUSH Region00.1005C5B0	h
10018F4F	PUSH Region00.10061C90	ncacn_np:%s[\\pipe\\%s]
10018FFC	PUSH Region00.10061CC0	ncacn_ip_tcp:%s

发动RPC攻击

快捷方式文件解析漏洞

- 这个漏洞利用Windows在解析快捷方式文件（例如.lnk文件）时的系统机制缺陷，使系统加载攻击者指定的DLL文件，从而触发攻击行为。

地址	反汇编	文本字串
100180A7	PUSH Region00.10061B30	{53f5630d-b6bf-11d0-94f2-00a0c91efb8b}
100180B2	PUSH Region00.100619A0	usbstor
100180B8	PUSH Region00.10061A80	storage#volume#
1001818E	MOV EBX,Region00.10061B30	{53f5630d-b6bf-11d0-94f2-00a0c91efb8b}
10018195	PUSH Region00.10061A80	storage#volume#
1001819A	MOV EDI,Region00.10061A0C	\\.\
100181A0	MOV EBP,Region00.10061BCC	%s%s%s#%s
100181C5	PUSH Region00.10061AA0	storage#volume#1&19f7e59c&0&
100181E4	PUSH Region00.10061A4C	storage#removablemedia#8&
100181EE	MOV EBP,Region00.10061BE0	%s%s%x&0&rm#%s
10018205	PUSH Region00.10061A18	storage#removablemedia#7&
10018226	PUSH Region00.100619EC	#{
10018462	PUSH Region00.1005D3F0	list<t> too long

打印机后台程序服务漏洞（MS10-061）

- Windows打印后台程序没有合理地设置用户权限
- Stuxnet蠕虫利用这个漏洞实现在内部局域网中的传播

地址	HEX 数据	反汇编	注释
10001073	> 8B45 0C	MOV EAX, DWORD PTR SS:[EBP+C]	
10001076	. 8B4D 10	MOV ECX, DWORD PTR SS:[EBP+10]	
10001079	. 8943 04	MOV DWORD PTR DS:[EBX+4], EAX	
1000107C	. C743 08 1C680	MOV DWORD PTR DS:[EBX+8], 222——?100168	winsta.exe
10001083	. 894B 0C	MOV DWORD PTR DS:[EBX+C], ECX	
10001086	. C743 14 A8770	MOV DWORD PTR DS:[EBX+14], 222——?10017	
1000108D	. C743 18 34680	MOV DWORD PTR DS:[EBX+18], 222——?100168	wbem\mof\sysnullevnt.mof
10001094	. C743 1C 3A060	MOV DWORD PTR DS:[EBX+1C], 63A	
1000109B	. E8 D04F0000	CALL 222——?10006070	
100010A0	. 83F8 01	CMP EAX, 1	
100010A3	.v 0F85 CB000000	JNZ 222——?10001174	
100010A9	. 8D95 A4F00000	LEA EDX, DWORD PTR SS:[EBP+F0A4]	
100010AF	. 52	PUSH EDX	
100010B0	. E8 0B5D0000	CALL 222——?10006DC0	
100010B5	. 83C4 04	ADD ESP, 4	
100010B8	. 83F8 01	CMP EAX, 1	
100010BB	.v 0F85 B3000000	JNZ 222——?10001174	
100010C1	. 68 BD010000	PUSH 1BD	
100010C6	. 56	PUSH ESI	
100010C7	. 8DBD A4F00000	LEA EDI, DWORD PTR SS:[EBP+F0A4]	
100010CD	. E8 5E010000	CALL 222——?10001230	
100010D2	. 83C4 08	ADD ESP, 8	
100010D5	. 85C0	TEST EAX, EAX	
100010D7	.v 75 16	JNZ SHORT 222——?100010EF	
100010D9	. 68 8B000000	PUSH 8B	
100010DE	. 56	PUSH ESI	
100010DF	. E8 4C010000	CALL 222——?10001230	
100010E4	. 83C4 08	ADD ESP, 8	
100010E7	. 85C0	TEST EAX, EAX	
100010E9	.v 0F84 85000000	JE 222——?10001174	

毒区病毒（Duqu)

- Duqu是一种复杂的木马，有迹象表明其制造者与臭名昭著的Stuxnet蠕虫创建者为同一人。
- 与Stuxnet比起来，Duqu更像是系统中的后门程序，主要目的是为私密信息的盗取提供便利。而Stuxnet则被用来进行工业破坏。
- Stuxnet能够运用各种方法将自己从一台计算机复制到另一台计算机上，而Duqu只是一种木马，目前没有发现自我复制的行为。

病毒特点

●Duqu创建的目的是用来收集与其攻击目标有关的情报，包括受攻击设备中所有以数字格式保存的信息。

●收集密码、抓取桌面截图（暗中监视用户的操作）、盗取各类文件感兴趣，与控制服务器（C&C）主机，将盗取的信息发送给主控服务器。

● Duqu通过对Word文档的CVE-2011-3402漏洞发起针对性攻击，进而感染计算机。该漏洞是在Windows核心组件Win32k.sys中的零日漏洞，它使得攻击者可以以最高级别权限运行代码，并绕过Windows或安全软件的大部分保护机制。

●从证书认证机构中盗取证书，而这些证书可以用作为恶意代码进行数字签名

病毒注入

Duqu木马采用了DLL注入方式来隐藏自身模块，以躲避杀毒软件的检测，并且都同时采用了驱动层注入和用户层注入两种方式。

通过PsSetLoadImageNotifyRoutine设置回调函数的方式来完成驱动层的注入。每当有PE程序（DLL或者EXE）被加载，这个函数都会发生回调，从而获得执行机会。如果加载的是kernel32.dll文件，则通过API名称的哈希值，获得kernel32.dll上一些特定的API函数地址。如果被加载是特定的进程名称（该名称以加密形式保存在注册表），则修改此进程的入口点函数跳转到注入代码执行恶意行为，然后跳回到原入口点（很像感染式病毒，不过是完全内存态的感染），成为蠕虫的傀儡进程。

火焰病毒（Flame)

- Flame是一种后门程序和木马病毒，同时又具有蠕虫病毒的特点。
- 只要背后的操控者发出指令，就能在网络、移动设备中进行自我复制。
- 一旦电脑系统被感染，将开始一系列复杂的行动，包括监测网络流量、获取截屏画面、记录音频对话、截获键盘输入等。
- 被感染系统中所有的数据都能通过链接传到指定的服务器，让操控火焰的人一目了然。

病毒特点

- 伪造微软的数字签名证书。被伪造签名的主体是Microsoft Enforced Licensing Intermediate PCA数字证书认证机构。
- 使用紧凑的编程语言Lua进行编写，更好的隐藏大量恶意代码。
- 对蓝牙设备的使用。当设备的蓝牙功能开启的时候，Flame可以将配置模块中的相关选项同时开启，当发现有设备靠近被感染的计算机时，就可以收集设备中的信息。有赖于这样的配置，它还能以受感染的计算机做为一个“灯塔”，发现通过蓝牙传输的设备，并为背后的操控者提供有关编入到设备信息中的恶意程序状态。

病毒注入

- “超级火焰”病毒的主体为一个名为MSSECMGR.OCX的DLL动态库，通过命令行“rundll32.exe MSSECMGR.OCX, DDEnumCallback”来实现病毒的加载。病毒运行后会将自身复制到System32目录下，并向services.exe、winlogon.exe、explorer.exe和iexplore.exe等程序中注入自身并实现加载。

- 该病毒进入系统后，会主动创建C:Program FilesCommon FilesMicrosoft SharedMSSecurityMgr的目录，在系统不同目录中生成多个文件，同时还会新创建HKLMSYSTEMCurrentControlSetControlLsaAuthentication Packages = "mssecmgr.ocx"注册表项

美&以合作

报道声称该恶意软件由美国国家安全局和以色列合作研发。类似震网病毒，可能都在 Olympic Games计划下开发出来。印度时报报道，目前有80家来自亚洲、欧洲和北美的服务器在操作这种病毒。美国和以色列都正式否认与此病毒有关。

病毒来源”

前车之鉴

杀毒软件厂商卡巴斯基指出，有证据显示，开发“火焰”病毒的国家可能与开发2010年攻击伊朗核项目的蠕虫病毒的国家相同。但是，他们尚未确定该病毒是否像攻击伊朗核项目的蠕虫病毒那样拥有特殊任务，并拒绝说出他们认为是谁开发了该病毒。

病毒分析

由于与曾经攻击伊朗核项目计算机系统的“震网病毒”相比，“火焰”病毒不仅更为智能，且其攻击目标和代码组成也有较大区别。“火焰”病毒的攻击机制更为复杂，且攻击目标具有特定地域的地点。

“火焰”病毒部分特征与先前发现的“震网”和“毒区”两款病毒类似，显示三种病毒可能“同宗”。网络分析专家认为，已形成“网络战”攻击群。“震网”病毒攻击的是伊朗核设施，“毒区”病毒攻击的是伊朗工业控制系统数据，而“火焰”病毒攻击的则是伊朗石油部门的商业情报。

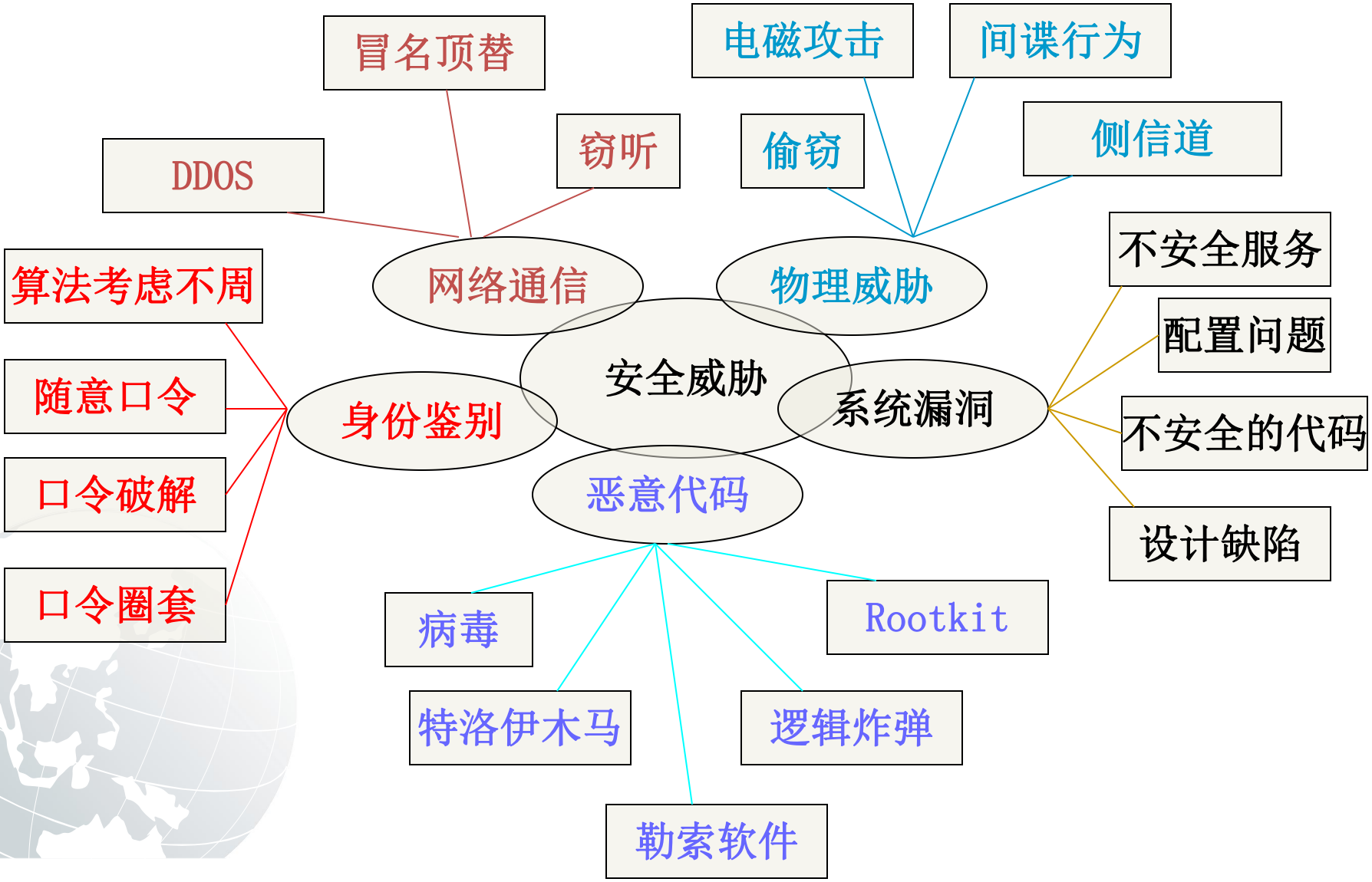
APT攻击

- 高级持续性威胁(Advanced Persistent Threat，APT)，APT（高级持续性渗透攻击）是一种以商业和政治为目的的网络犯罪类别，通常使用先进的攻击手段对特定目标进行长期持续性的网络攻击，具有长期经营与策划、高度隐蔽等特性。这种攻击不会追求短期的收益或单纯的破坏，而是以步步为营的渗透入侵策略，低调隐蔽的攻击每一个特定目标，不做其他多余的活动来打草惊蛇。

信息安全的主要威胁

- 操作系统、数据库以及通信协议等方面存在安全漏洞和隐蔽通道等不安全因素
- 软硬件故障和工作人员误操作等人为或偶然事故构成的威胁
- 利用计算机实施盗窃、诈骗等违法犯罪活动的威胁
- 网络攻击和计算机病毒构成的威胁
- 信息战的威胁

信息安全的主要威胁


安全威胁
网络通信
冒名顶替
DDOS
窃听
物理威胁
电磁攻击
间谍行为
偷窃
侧信道
系统漏洞
不安全服务
配置问题
不安全的代码
设计缺陷
身份鉴别
算法考虑不周
随意口令
口令破解
口令圈套
恶意代码
病毒
特洛伊木马
勒索软件
逻辑炸弹
Rootkit

主要的攻击手段

- 口令破解
- 病毒
- 木马
- **Rootkit**
- **DDoS（Distributed Denial of Service）**
- 勒索软件
- 系统漏洞利用
- 网络欺诈
- 社会工程
- 其它

信息系统安全概述

1 安全威胁及实例

2 信息安全基本概念及方法

3 安全模型

什么是信息安全

- **信息安全：（Information Security）**

国际标准化组织（ISO）对计算机系统安全的定义：为数据处理系统建立和采用的技术和管理的安全保护，保护计算机硬件、软件和数据不因偶然和恶意的原因遭到破坏、更改和泄露。

什么是信息安全

- **网络安全（Network Security)：**
  计算机网络环境下的信息安全。

- **网络空间安全（ Cybersecurity or Cyberspace Security)**
  包含： 物理空间、网络空间和社会空间的安全。

信息安全的特征

- 三个基本特性

(1) 机密性

(2) 完整性

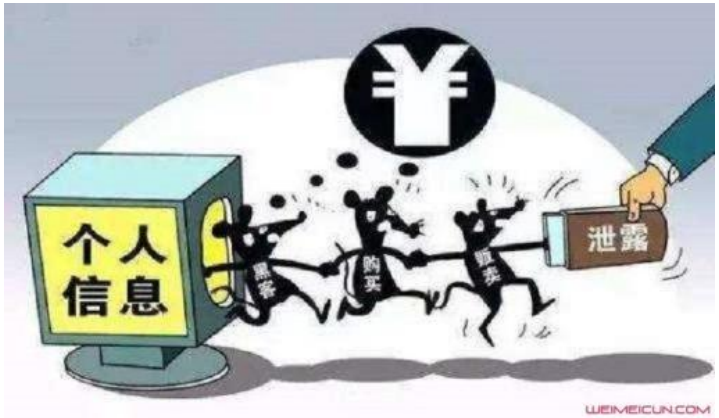
(3) 可用性

信息安全的特征

- 机密性（Confidentiality or Secrecy)

确保信息不被非授权者获得与使用。

例如： 信息泄露，例如密码，文件等



信息安全的特征

●完整性（ Integrity)

信息是真实可信的，其发布者不被冒充，来源不被伪造，内容不被篡改。

例如： 身份伪造、文件篡改

信息安全的特征

●可用性（ Availability)

保证信息可被授权人在需要时立即获得并正常使用。

例如： DDOS、勒索软件等

信息安全主要防御技术及手段

- 口令破解 → 密码策略、加密、Hash加盐
- 病毒
- 木马
- Rootkit
- 系统漏洞利用

  病毒查杀、防病毒软件
  Bug检测：模糊测试、漏洞挖掘
  风险评估：渗透测试、安全评估
  系统加固：硬件安全、身份认证、访问控制、驱动签名、可信计算、内存防御等
- 网络攻击与DDoS → 防火墙、IDS、IPS
- 勒索软件 → 软件行为分析
- 信息及隐私泄露 → 机密计算、同态计算、差分隐私等
- 网络欺诈 → 身份认证、大数据分析
- 社会工程 → 信息安全管理

信息系统安全概述

1 安全威胁及实例

2 信息安全基本概念及方法

3 安全模型

信息安全的本质

攻防对抗

信息安全的

- 攻防对抗
  - 非势均力敌
  - 无处不在的敌手
  - 防不胜防
  - 没有100%安全的系统，安全是相对对的（每1000行就有1个安全漏洞）

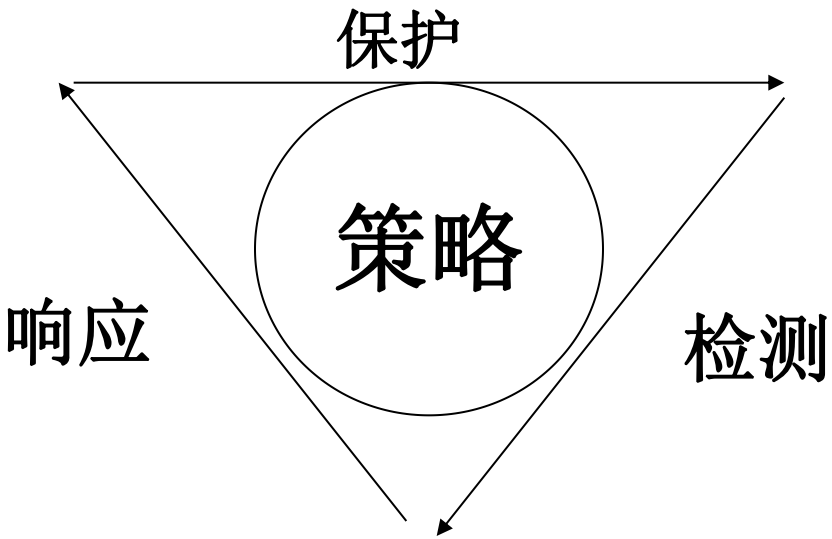
截至2014年底，全国信息安全人只有6万余。全国2500多所高校中，开设信息安全专业的仅有103所，其中博士点硕士点不到40个，每年我国信息安全专业毕业生不足1万人，信息安全专业人才缺口70万。

而根据《报告》对2014收入统计，信黑客数量？匿

Windows XP 大约40,000,
Windows Vista 大约50,00
码。
Windows 7 大约50,000,0

安全模型

- P^2DR安全模型（美国国际互连网安全系统公司ISS提出）（动态信息安全理论的主要模型）



Policy（安全策略）、
Protection（防护）
Detection（检测）
Response （响应）

安全=风险分析+执行策略+系统实施+漏洞检测+实时响应

Policy(安全策略)

- 由于安全策略是安全管理的核心，所以要想实施动态网络安全循环过程，必须首先制定安全策略，所有的防护、检测、响应都是依据安全策略实施的，安全策略为安全管理提供管理方向和支持手段。
- 对于一个策略体系的建立包括：安全策略的制订、安全策略的评估、安全策略的执行等。

Protection（保护）

- 保护通常是通过采用一些传统的静态安全技术及方法来实现的，主要有防火墙、加密、认证等方法。通过防火墙监视限制进出网络的数据包，可以防范外对内及内对外的非法访问，提高了网络的防护能力，当然需要根据安全策略制定合理的防火墙策略；也可以利用SecureID这种一次性口令的方法来增加系统的安全性等等。

Detection（检测）

- 在网络安全循环过程中，检测是非常重要的一个环节，检测是动态响应的依据，它也是强制落实安全策略的有力工具，通过不断地检测和监控网络和系统，来发现新的威胁和弱点，通过循环反馈来及时作出有效的响应。

Response（响应）

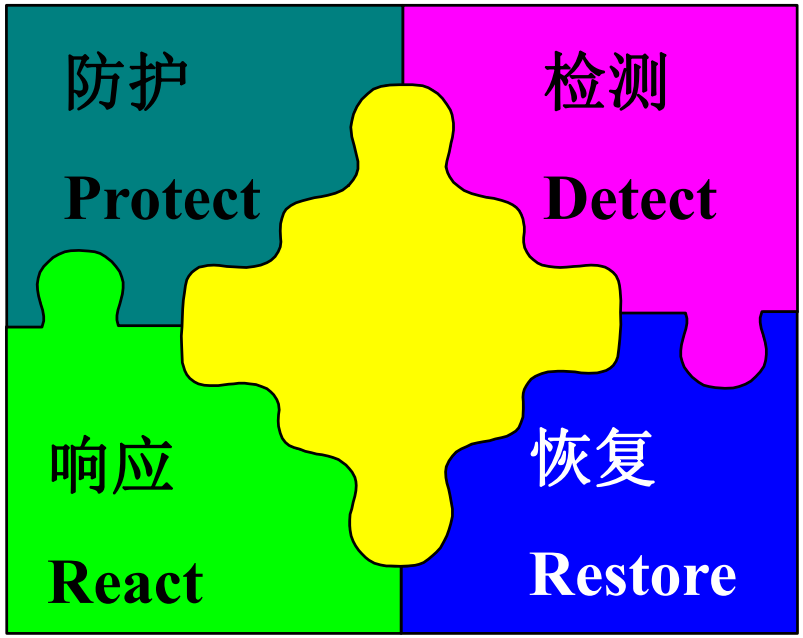
紧急响应在安全系统中占有最重要的地位，是解决安全潜在性最有效的办法。从某种意义上讲，安全问题就是要解决紧急响应和异常处理问题。要解决好紧急响应问题，就要制订好紧急响应的方案，做好紧急响应方案中的一切准备工作。

PDRR安全模型

美国国防部提出

防护、检测、响应、恢复

安全的目标实际上就是尽可能地增大保护时间，减少检测和响应时间，在系统遭受破坏之后，应尽可能快的恢复，减少系统暴露的时间。



Protect（防护）

- 网络安全策略PDRR模型的最重要的部分就是防护（P ）。防护是预先阻止攻击可以发生的条件，让攻击者无法顺利地入侵。
- 防护可以减少大多数的入侵事件。

Detect（检测）

- PDRR模型的第二个环节就是检测（D）。上面提到防护系统除掉入侵事件发生的条件，可以阻止大多数的入侵事件的发生，但是它不能阻止所有的入侵。特别是那些利用新的系统缺陷、新的攻击手段的入侵。因此安全策略的第二个安全屏障就是检测，即如果入侵发生就检测出来，这个工具是入侵检测系统（IDS）。

React（响应）

- PDRR模型中的第三个环节就是响应（R）。响应就是已知一个攻击（入侵）事件发生之后，进行处理。在一个大规模的网络中，响应这个工作都是有一个特殊部门负责，那就是计算机响应小组。世界上第一个计算机响应小组CERT，位于美国于1989年建立，是世界上最著名的计算机响应小组。从CERT建立之后，世界各国以及各机构也纷纷建立自己的计算机响应小组。我国第一个计算机紧急响应小组CCERT，于1999年建立，主要服务于中国教育和科研网。

Restore（恢复）

- 恢复是PDRR模型中的最后一个环节。恢复是事件发生后，把系统恢复到原来的状态，或者比原来更安全的状态。恢复也可以分为两个方面：系统恢复和信息恢复。系统恢复指的是修补该事件所利用的系统缺陷，不让黑客再次利用这样的缺陷入侵。一般系统恢复包括系统升级、软件升级和打补丁等。系统恢复的另一个重要工作是除去后门。一般来说，黑客在第一次入侵的时候都是利用系统的缺陷。在第一次入侵成功之后，黑客就在系统打开一些后门，如安装一个特洛伊木马。

成功的安全模型

在安全和通信方便之间建立平衡

-能够对存取进行控制

-保持系统和数据完整

-能对系统进行恢复和数据备份

安全工作的目的一

- 安全工作的目的就是为了在安全法律、法规、政策的支持与指导下，通过采用技术与安全管理措施，完成以下任务：

  使用访问控制机制，即“进不来”，阻止非授权用户进入网络，保证网络可用。

  使用授权机制，实现对用户的权限控制，即不该拿走的“拿不走”，同时结合内容审计机制，实现对网络资源及信息的可控性。

  使用加密机制，确保信息不暴露给未授权的实体或进程，即“看不懂”，从而实现信息的保密性。

安全工作目的二

- 使用数据完整性鉴别机制，保证只有得到允许的人才能修改数据，而其它人“改不了”，从而确保信息的完整性。
- 使用审计、监控、防抵赖等安全机制，使得攻击者、破坏者、抵赖者“走不脱”，并进一步对网络出现的安全问题提供调查依据和手段，实现信息的可审查性。

本章总结

- 掌握信息系统安全的概念和基本属性
- 了解目前主要的安全威胁和攻击手段
- 了解导致安全威胁的原因
- 了解主要的信息安全防御技术
- 熟悉PPDR安全模型
- 了解安全工作的主要目的

课程实验

- 软件安全和恶意代码
  - 实验：

    基于OllyDbg的恶意代码分析

    安装Ubuntu或KALI,熟悉linux系统使用

    提前准备！

鸟哥私房菜　unix环境高级编程

谢　　谢！